Engineering and Secure Implementation of a Two-Player Video Game Diagnostic for ADHD and Autism

Yinan Sun[1], Aditi Jaiswal[2], Aayush Nandkeolyar[3], Kaitlyn Dunlap[4], Katy Tarrit[2], Dennis P Wall[4], Peter Washington[3]

[1]The Ohio Division of Cancer Prevention and Control, Department of Internal Medicine, The Ohio State Comprehensive Cancer Center

[2]Department of Information and Computer Sciences, University of Hawai‘i at Mānoa

[3]Division of Clinical Informatics and Digital Transformation (DoC-IT), Department of Medicine, University of California, San Francisco (UCSF)

[4]Departments of Pediatrics (Clinical Informatics), Biomedical Data Science, and Psychiatry & Behavioral Sciences, Stanford University

ABSTRACT

We describe how a two-player, browser-based assessment platform (SocialPlai) that records short video and audio clips for ADHD/autism research was engineered to run inside UCSF's HIPAA-aligned cloud environment. The deployment of the website, SocialPlai.UCSF.edu, relies on a segregated AWS account governed by UCSF security controls, inbound HTTPS via enterprise load-balancing and network translation, strict perimeter rules, institution-issued TLS, and service integrations to institutional middleware. We distill these choices into a reusable blueprint that other academic centers can adapt to ship similar data-collecting digital diagnostics safely.

INTRODUCTION

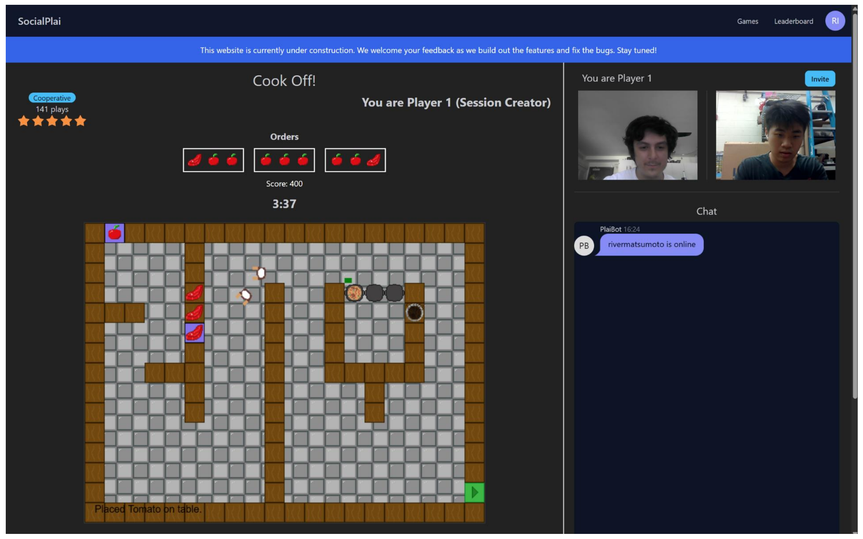
Video-first digital diagnostics create translational value only if they can be operated in routine settings without privacy breaches or brittle ad-hoc infrastructure. Instead of focusing on model accuracy, we report the operational controls, data-path design, and governance hooks needed to run a real system that ingests PHI/PII at scale while remaining auditable and maintainable.

WHAT IS SOCIALPLAI?

SocialPlai (SocialPlai.UCSF.edu) delivers short, two-player games via the web in order to elicit social and attention-related behaviors (**Figure 1**). During gameplay, the browser captures video, audio, and minimal metadata, which are stored for downstream multimodal learning. Our goal is to supply a replicable pattern that allows institutions to host such tools within a secure academic medical-center cloud.

METHODOLOGY

Figure 1. Two-player computer games are designed to capture behavioral features relevant to diagnosing ADHD and autism.



SocialPlai runs in a UCSF-managed, restricted AWS account that is dedicated to sensitive applications and that contains a VPC with public and private subnets. An enterprise load balancer terminates HTTPS connections and performs network address translation so that only port 443 is exposed to the internet. Security groups and network ACLs enforce least-privilege ingress and egress, and administrative access requires VPN and multi-factor authentication. TLS certificates are issued by the institution's certificate authority rather than by external providers. Outbound integrations to institutional services, such as the enterprise API gateway, are limited to an approved allow list.

IMPLEMENTATION GUIDELINES

Security and Compliance Controls: All traffic uses TLS with HSTS, and the application does not serve mixed content. Administrative access is gated by enterprise single sign-on, VPN, and multi-factor authentication, and application users receive role-appropriate permissions. Data at rest and in transit are encrypted, storage buckets and keys are tightly scoped, lifecycle policies are enforced, and public access is explicitly denied. Changes to infrastructure are managed as code with peer review and with clear separation between development, staging, and production environments. Centralized logging captures events at the load-balancer and application layers, logs are rendered tamper-evident, and alerts notify operators of policy violations.

Governance and Operations: The deployment of SocialPlaid epended on close collaboration with UCSF's institutional cloud services team, which provisioned the account, firewalls, DNS, and certificates, and who staged security reviews before live deployment. Notably, the security review identified several security vulnerabilities in SocialPlai's code base, such as transfer of some data over HTTP rather than HTTPS, using out-of-date versions of third party libraries, form autocomplete turned on in form fields for sensitive patient data, and misconfigured HTTP request response headers.

Creating a Similar System Within Your Institution: Institutions seeking to reproduce this approach should first request a restricted cloud account that is authorized for PHI workloads (or go through the tedious procedure of configuring their AWS account to be HIPAA-compliant). You should enforce least-privilege security rules and require VPN and multi-factor authentication for all administrators. Integrations with institutional middleware should be limited to allow-listed egress destinations, and centralized logging and monitoring should be configured with appropriate retention and alerting. Finally, incident response and rollback procedures should be documented and tested before study enrollment.

Aiding Other Digital Health Research Groups: Research groups with limited DevOps capacity can adopt this secure-by-default baseline to stand up similar applications quickly and responsibly. We are also open to consulting with research groups who need some technical advice for creating a similar system that is secure and approved for PHI.

ACKNOWLEDGEMENTS

This work was funded by the National Institutes of Health (DP2EB035858) via the Director's New Innovator Award. The content is solely the responsibility of the authors and does not necessarily represent the official views of the National Institutes of Health.